

Modelo de Encuesta Integral sobre Preparación y Métricas CRA

Versión: 1.0

Ámbito: Empresas que diseñan, fabrican, integran, distribuyen o explotan productos con elementos digitales bajo el paraguas del Cyber Resilience Act (CRA).

0. Instrucciones generales

Esta encuesta pretende comprender hasta qué punto su organización está preparada —en la teoría, en la práctica y en las largas tardes de incidentes— para un mundo en el que el CRA ya no es un borrador lejano, sino un hecho regulatorio consumado.

No buscamos “respuestas perfectas”, sino una radiografía honesta. Puede responder en nombre de toda la organización si tiene visibilidad transversal; en caso contrario, responda desde la perspectiva de su unidad, indicando el alcance al final.

1. Perfil de la organización

1.1 Datos básicos

P1. Tipo principal de actividad de su organización (marque la opción predominante):

- ☐ Fabricante de productos con elementos digitales (hardware, software embebido, IoT, etc.)
- ☐ Desarrollador de software independiente (software puro, SaaS, plataformas)
- ☐ Integrador de sistemas / proveedor de servicios gestionados
- ☐ Distribuidor / importador de productos con elementos digitales
- ☐ Usuario final intensivo (operador de servicios esenciales, infraestructuras críticas, AA.PP.)
- ☐ Otro (especificar): _____

P2. Tamaño aproximado de la organización (a nivel global):

- ☐ Micro (1–9 personas)
- ☐ Pequeña (10–49 personas)
- ☐ Mediana (50–249 personas)
- ☐ Grande (≥ 250 personas)

P3. Presencia en el mercado de la UE:

- ☐ Sin actividad directa en la UE (pero suministramos a terceros con actividad en la UE)
- ☐ Operamos en 1–2 Estados miembros
- ☐ Operamos en 3–10 Estados miembros
- ☐ Operamos en más de 10 Estados miembros

P4. Rol del/de la respondente en la organización:

- ☐ Dirección (CEO, COO, Director General)
- ☐ CISO / Responsable de Seguridad de la Información
- ☐ CTO / Dirección de Tecnología / Ingeniería
- ☐ Dirección de Producto / Calidad / Conformidad
- ☐ Asesoría Jurídica / Compliance
- ☐ Otra posición (especificar): _____

2. Conocimiento y gobernanza del CRA

2.1 Nivel de conocimiento

P5. ¿Cómo describiría el nivel de conocimiento del CRA en su organización?

- ☐ No hemos oído hablar del CRA (o lo confundimos con una nueva moda de zapatillas)
- ☐ Conocimiento básico en el equipo de seguridad o legal, limitado en el resto
- ☐ Conocimiento intermedio en varios equipos clave (seguridad, legal, producto)
- ☐ Conocimiento avanzado y estructurado en la mayoría de áreas relevantes
- ☐ El CRA es parte central de nuestra estrategia de producto y cumplimiento

P6. ¿Existe una persona o función claramente designada como responsable interna del cumplimiento del CRA?

- ☐ Sí, una persona designada con dedicación significativa
- ☐ Sí, un equipo o comité interfuncional
- ☐ Se asume que es responsabilidad del CISO
- ☐ Se asume que es responsabilidad del asesor jurídico / compliance
- ☐ No, aún no está definido
- ☐ No, y honestamente no vemos la urgencia

2.2 Integración en la gobernanza

P7. ¿En qué medida el CRA está integrado en la gobernanza corporativa (comités, reporting al Consejo, etc.)?

- ☐ No se trata en ningún órgano formal de gobierno
- ☐ Se menciona de forma ad hoc, sin un punto fijo en la agenda
- ☐ Tiene un punto recurrente en comités técnicos o de riesgo
- ☐ Se informa periódicamente al Consejo o máximo órgano de gobierno
- ☐ El Consejo ha aprobado políticas específicas ligadas al CRA (apetito de riesgo, inversiones, etc.)

P8. ¿Dispone su organización de una política formal de “producto seguro por diseño y por defecto” alineada con el CRA?

- ☐ Sí, aprobada y en vigor, con revisiones periódicas
- ☐ Sí, pero aún en implementación
- ☐ En borrador
- ☐ No, pero nos apoyamos en prácticas informales de ingeniería
- ☐ No, y no es una prioridad actual

3. Alcance de productos y conformidad CRA

3.1 Inventario y clasificación

P9. ¿Dispone su organización de un inventario actualizado de productos con elementos digitales potencialmente cubiertos por el CRA?

- ☐ Sí, completo, centralizado y actualizado al menos trimestralmente
- ☐ Sí, pero parcial o distribuido entre varias áreas
- ☐ En elaboración
- ☐ No, no tenemos un inventario específico orientado a CRA

P10. ¿Clasifica su organización dichos productos por categorías de riesgo o criticidad (por ejemplo, impacto en seguridad, vida humana, infraestructuras críticas)?

- ☐ Sí, con un modelo formal y criterios documentados
- ☐ Sí, pero el modelo es aún informal o poco consistente
- ☐ Estamos diseñando el modelo
- ☐ No, tratamos todos los productos de forma similar por defecto

3.2 Estado de conformidad (autoevaluado)

P11. ¿Cuál es el estado aproximado de conformidad CRA de su cartera de productos (estimación interna, aunque no esté auditada)?

- ☐ 0–25 % de los productos está razonablemente alineado con CRA
- ☐ 26–50 %
- ☐ 51–75 %
- ☐ 76–100 %
- ☐ No disponemos de esta estimación

P12. En relación con la necesidad de certificación (por ejemplo, a través de EUCC u otros esquemas armonizados), su organización:

- ☐ Ha identificado qué productos requerirán certificación y en qué nivel
- ☐ Está todavía analizando qué productos podrían necesitar certificación
- ☐ Confía únicamente en la autoevaluación y documentación técnica
- ☐ No ha abordado aún el tema de certificación

4. Desarrollo seguro, SBOM y ciclo de vida

4.1 Prácticas de desarrollo seguro

P13. ¿Hasta qué punto están integrados los requisitos de seguridad y CRA en el ciclo de desarrollo (SDLC) de sus productos?

- ☐ Integrados desde la fase de ideación / requisitos (security & CRA by design)
- ☐ Considerados en las fases de diseño y pruebas, pero no desde el inicio
- ☐ Tratados como una fase de “endurecimiento” previa al lanzamiento
- ☐ Principalmente reactivos, en respuesta a incidentes o auditorías
- ☐ No existe integración sistemática conocida

P14. ¿Utilizan modelos o normativas de referencia (ISO/IEC 27001, 62443, NIST, etc.) mapeados explícitamente a los requisitos del CRA?

- ☐ Sí, tenemos mapeos formales a uno o varios estándares
- ☐ Sí, pero el mapeo es parcial e informal
- ☐ No, pero lo estamos considerando
- ☐ No, y no vemos valor en hacerlo actualmente

4.2 Materiales de lista de componentes (SBOM) y dependencias

P15. En relación con SBOM (Software Bill of Materials) para sus productos:

- ☐ Disponemos de SBOM completos y automatizados para la mayoría de los productos
- ☐ Disponemos de SBOM parciales o manuales
- ☐ Estamos en proceso de implantación de SBOM
- ☐ No utilizamos SBOM ni tenemos planes inmediatos de hacerlo

P16. ¿Cómo gestiona su organización las dependencias de terceros (bibliotecas, firmware, servicios) en términos de vulnerabilidades?

- ☐ Monitoreo continuo automatizado, con criterios de criticidad y SLA de remediación
- ☐ Revisiones periódicas manuales y remediación case by case
- ☐ Revisiones puntuales ligadas a releases importantes
- ☐ No existe un proceso sistemático identificado

5. Gestión de vulnerabilidades y parches (indicadores clave CRA)

5.1 Proceso y tiempos

P17. ¿Dispone su organización de un proceso formal de gestión de vulnerabilidades para productos cubiertos por el CRA?

- ☐ Sí, con procedimientos documentados y roles definidos
- ☐ Sí, pero sólo a nivel de buenas prácticas conocidas internamente
- ☐ En fase de diseño o implantación
- ☐ No, se trata de forma ad hoc

P18. Indique, de forma aproximada, el tiempo medio entre la identificación de una vulnerabilidad crítica en un producto y la disponibilidad de un parche (time to patch – TTP):

- ☐ Menos de 7 días
- ☐ Entre 7 y 30 días
- ☐ Entre 31 y 90 días
- ☐ Más de 90 días
- ☐ No medimos este indicador

P19. ¿Monitorizan el porcentaje de instalaciones de sus productos que han aplicado un parche crítico dentro de un plazo determinado (por ejemplo, 30 días)?

- ☐ Sí, con visibilidad detallada por cliente o segmento
- ☐ Sí, pero sólo de forma agregada (“aproximadamente X %”)
- ☐ Sólo en algunos productos o servicios conectados
- ☐ No, carecemos de visibilidad suficiente

5.2 Coordinated Vulnerability Disclosure (CVD)

P20. ¿Cuenta su organización con una política pública de Coordinated Vulnerability Disclosure (CVD) o programa de bug bounty?

- ☐ Sí, con canal público y procesos establecidos
- ☐ Sí, pero el proceso es todavía experimental
- ☐ En preparación
- ☐ No, y no lo tenemos previsto
- ☐ No, pero manejamos casos puntuales informalmente

6. Incidentes, notificación y resiliencia operativa

6.1 Detención y respuesta

P21. Para incidentes relacionados con productos sujetos al CRA, ¿miden sistemáticamente el tiempo medio de detección (MTTD)?

- ☐ Sí, y lo reportamos regularmente a la dirección
- ☐ Sí, pero sólo en algunos entornos (por ejemplo, SOC interno)
- ☐ No, pero recolectamos datos que podrían permitirlo
- ☐ No, no se mide

P22. ¿Miden el tiempo medio de contención / recuperación (MTTC/MTTR) de dichos incidentes?

- ☐ Sí, con objetivos definidos (SLO) por tipo de producto/cliente
- ☐ Sí, pero sin objetivos explícitos
- ☐ No, aunque podríamos reconstruirlo a posteriori
- ☐ No, no se mide

6.2 Notificación CRA y coordinación

P23. ¿Dispone su organización de procedimientos preparados para cumplir los plazos de notificación de vulnerabilidades explotadas e incidentes graves establecidos por el CRA (p.ej. 24 horas)?

- ☐ Sí, con playbooks probados (simulaciones, ejercicios)
- ☐ Sí, pero sólo documentados sobre el papel
- ☐ Estamos definiéndolos
- ☐ No, confiamos en improvisar en caso de necesidad

P24. ¿Quién coordina la notificación a las autoridades (ENISA, autoridades nacionales, CSIRTs, etc.) en caso de incidente CRA?

- ☐ CISO o equipo de seguridad
- ☐ Legal / Compliance
- ☐ Equipo de Producto / Ingeniería
- ☐ Equipo de Comunicación / Relaciones institucionales
- ☐ Depende del tipo de incidente
- ☐ No está definido

7. Métricas, KPIs y reporting interno

7.1 Cuadro de mando CRA

P25. ¿Dispone su organización de un cuadro de mando (dashboard) con indicadores específicos relacionados con el CRA?

- ☐ Sí, consolidado y accesible para alta dirección y áreas clave
- ☐ Sí, pero disperso en varios informes
- ☐ En desarrollo
- ☐ No, usamos indicadores genéricos de ciberseguridad

P26. ¿Con qué frecuencia se reportan métricas relevantes para CRA a la alta dirección o al máximo órgano de gobierno?

- ☐ Mensual
- ☐ Trimestral
- ☐ Anual
- ☐ Sólo en caso de incidentes importantes
- ☐ No se reportan de forma estructurada

7.2 Indicadores utilizados (selección)

P27. Indique cuáles de los siguientes indicadores se miden de forma sistemática (marque todos los que apliquen):

- ☐ Número de productos alineados con requisitos CRA vs. total de productos
- ☐ Número de vulnerabilidades críticas abiertas en productos CRA
- ☐ Edad media de vulnerabilidades críticas (en días)
- ☐ TTP (tiempo medio hasta parche)
- ☐ Porcentaje de clientes/instalaciones con parche aplicado en plazo objetivo
- ☐ Número de incidentes significativos relacionados con productos CRA
- ☐ Pérdidas económicas estimadas ligadas a dichos incidentes
- ☐ Gasto en seguridad y cumplimiento CRA como % del presupuesto TIC o I+D
- ☐ Cobertura de ciberseguro relacionada con productos
- ☐ Otros (especificar): _____

8. Capacidades, formación y cultura

8.1 Recursos y capacidades

P28. ¿Considera que su organización dispone de recursos suficientes (humanos, técnicos, presupuestarios) para abordar el cumplimiento CRA?

- ☐ Sí, sobradamente (algo raro, pero suceder sucede)
- ☐ Sí, razonablemente
- ☐ A duras penas
- ☐ Claramente no
- ☐ No se ha analizado

P29. ¿Existen programas de formación específicos sobre CRA dirigidos a los equipos relevantes (producto, desarrollo, seguridad, legal, ventas, etc.)?

- ☐ Sí, programas estructurados y recurrentes
- ☐ Sí, formación puntual (por ejemplo, talleres o sesiones únicas)
- ☐ Previsto, pero aún no implementado
- ☐ No, y no está previsto

8.2 Cultura y apetito de riesgo

P30. ¿Cómo describiría la actitud de la alta dirección respecto al CRA?

- ☐ Lo perciben como una prioridad estratégica y de competitividad
- ☐ Lo perciben como un riesgo regulatorio importante que hay que gestionar
- ☐ Lo ven como un coste inevitable, pero sin valor añadido evidente
- ☐ Lo consideran un tema secundario o “de técnicos”
- ☐ No hay una opinión clara o articulada

9. Impacto económico, IGM y ROI

(Las respuestas de esta sección alimentarán el cálculo del Índice Global de Madurez (IGM) y estimaciones de retorno de la inversión (ROI) en CRA.)

P31. Aproximadamente, ¿qué porcentaje del presupuesto anual TIC / I+D se destina a ciberseguridad y cumplimiento (incluyendo CRA, NIS2, etc.)?

- ☐ < 3 %
- ☐ 3–5 %
- ☐ 6–10 %
- ☐ 11–15 %
- ☐ > 15 %
- ☐ No se dispone de dato

P32. De ese presupuesto de ciberseguridad y cumplimiento, ¿qué proporción estima que está directa o indirectamente relacionada con requisitos CRA (desarrollo seguro, refactorización de productos, SBOM, certificaciones, etc.)?

- ☐ < 10 %
- ☐ 10–25 %
- ☐ 26–50 %
- ☐ > 50 %
- ☐ Imposible de estimar con los datos actuales

P33. En los últimos 12 meses, ¿ha sufrido su organización incidentes significativos ligados a vulnerabilidades en productos digitales que, de haber estado plenamente alineados con CRA, podrían haberse evitado o mitigado?

- ☐ Sí, varios
- ☐ Sí, uno o dos
- ☐ No
- ☐ No lo sabemos con certeza

P34. Si ha respondido “Sí” en la anterior, estime la magnitud económica agregada (orden de magnitud):

- ☐ < 50.000 €
- ☐ 50.000–250.000 €
- ☐ 250.000–1.000.000 €
- ☐ > 1.000.000 €
- ☐ Prefiero no indicarlo / no lo sabemos

10. Perspectivas, retos y apoyo necesario

10.1 Principales retos

P35. ¿Cuáles son los principales retos percibidos para cumplir con el CRA? (marque hasta tres)

- ☐ Falta de claridad regulatoria / interpretativa
- ☐ Complejidad técnica (productos heredados, OT, etc.)
- ☐ Coste económico de adaptación
- ☐ Escasez de talento especializado
- ☐ Dependencia de proveedores y cadena de suministro
- ☐ Integración con otros marcos (NIS2, ISO, etc.)
- ☐ Falta de prioridad interna
- ☐ Otros (especificar): _____

10.2 Apoyos y expectativas

P36. ¿Qué tipo de apoyo externo valoraría más para avanzar en la preparación CRA?

- ☐ Guías técnicas sectoriales y ejemplos prácticos
- ☐ Herramientas de autodiagnóstico y plantillas de documentación
- ☐ Programas de formación específicos
- ☐ Incentivos económicos o fiscales
- ☐ Espacios de coordinación sectorial (foros, grupos de trabajo)
- ☐ Otros: _____

11. Comentarios finales

P37. Si quiere compartir alguna reflexión adicional sobre el CRA, su grado de realismo, su potencial transformador o sus efectos colaterales —incluida la salud mental de sus equipos—, este es el lugar:

Fin del cuestionario.